

GESTIONE DI GRUPPI E PERMESSI - WINDOWS SERVER 2022

Obiettivo: creare e configurare gruppi e utenti in un dominio Windows Server 2022, assegnando permessi differenti per file e cartelle, restrizioni delle funzionalità di sistema e accesso remoto al server.

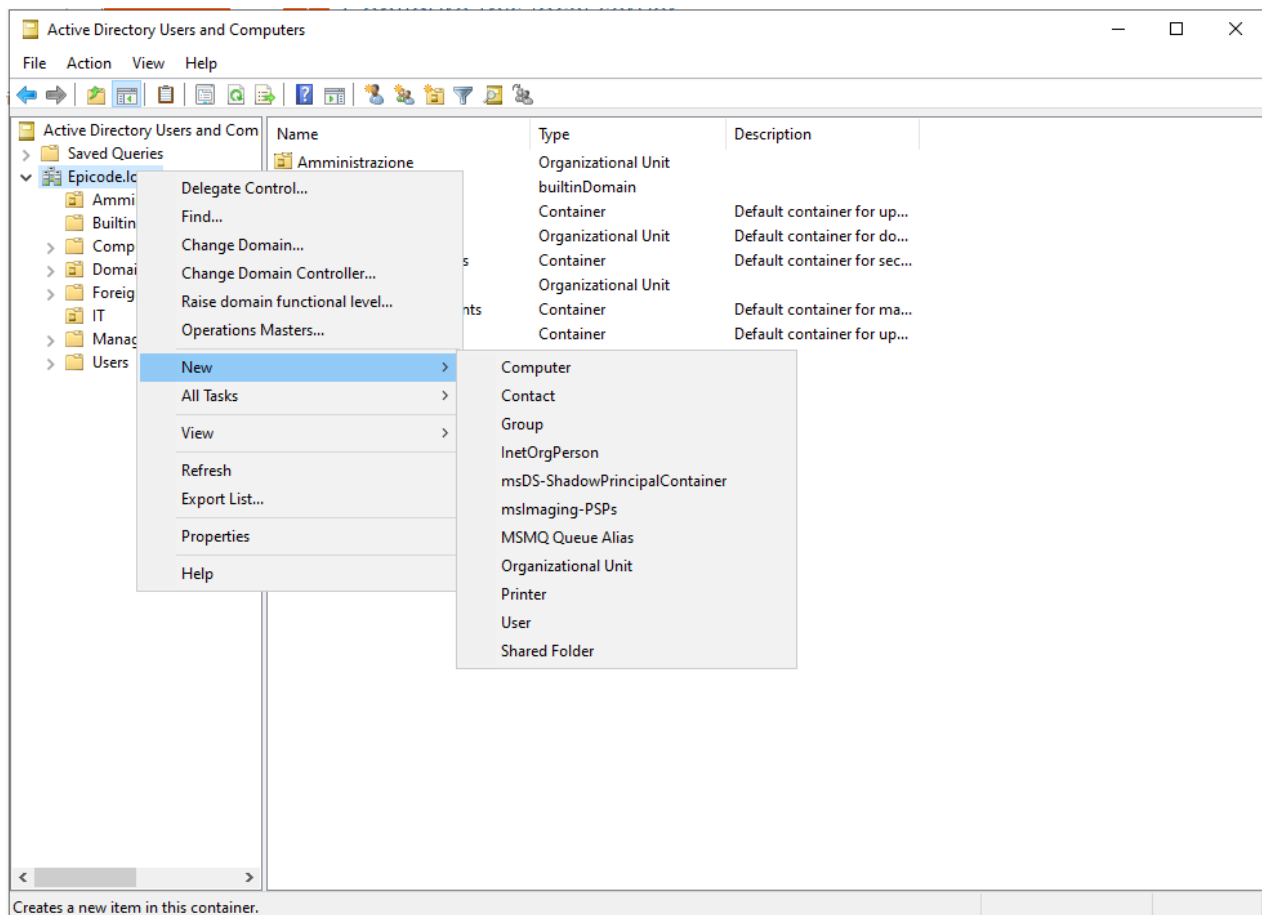
Scenario di laboratorio: è stata simulata l'infrastruttura di una piccola università, separando i ruoli tra Amministrazione, reparto IT, utenti dei Laboratori e Ospiti che utilizzano postazioni pubbliche, ad esempio in una biblioteca.

Ambiente di laboratorio: Windows Server 2022 configurato come Domain Controller del dominio EPICODE.LOCAL e un client Windows 10 collegato al dominio per le verifiche.

Strumenti utilizzati: Active Directory Users and Computers, Group Policy Management, File Explorer, Server Manager e Connessione Desktop remoto.

1. Creazione della struttura in Active Directory

Per organizzare utenti e privilegi sono state predisposte unità organizzative dedicate. La separazione consente di applicare policy differenti e di associare le autorizzazioni ai gruppi di sicurezza in base al ruolo svolto nell'infrastruttura universitaria.



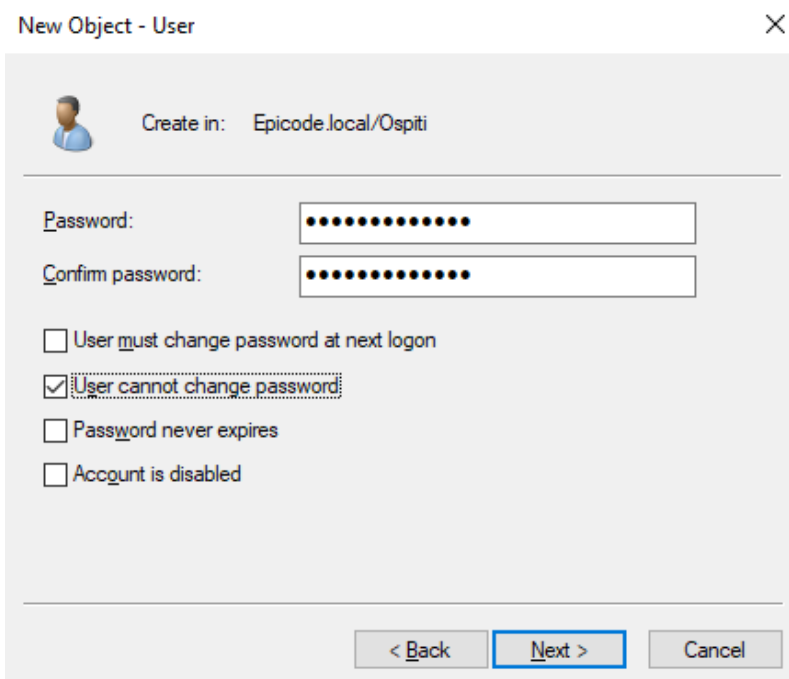
1 - Sopra: Creazione di un nuovo oggetto in Active Directory Users and Computers; tra le opzioni disponibili è presente Organizational Unit.

1.1 Gruppi e utenti configurati

La struttura è stata suddivisa in quattro aree principali. All'interno di ciascuna Organizational Unit è stato creato un gruppo di sicurezza omonimo: nell'OU Amministrazione il gruppo Amministrazione, con gli utenti Chiara Rossi e Claudio Foresta; nell'OU IT il gruppo IT, con Teresa Grassi e Marco Antonio; nell'OU Laboratori il gruppo Laboratori, con classe1 e classe2; nell'OU Ospiti il gruppo Ospiti, con ospite1 e ospite2. I gruppi vengono utilizzati per assegnare autorizzazioni e policy in base al ruolo svolto nell'infrastruttura.

Area / gruppo	Utenti	Funzione
Amministrazione	Chiara Rossi; Claudio Foresta	Gestione dei documenti amministrativi e dei dati riservati.
IT	Marco Antonio; Teresa Grassi	Gestione tecnica, manutenzione e accesso remoto al server.
Laboratori	Classe1; Classe2	Utilizzo delle risorse condivise per le attività di laboratorio.
Ospiti	ospite1; ospite2	Postazioni pubbliche con funzionalità di sistema limitate.

Per gli utenti dei gruppi Amministrazione e IT è stato impostato il cambio obbligatorio della password al primo accesso tramite l'opzione User must change password at next logon. Per gli utenti dei gruppi Laboratori e Ospiti è stata invece selezionata l'opzione User cannot change password, così da impedire la modifica autonoma della password durante il laboratorio.



New Object - User

Create in: Epicode.local/Ospiti

Password: [dots]

Confirm password: [dots]

☐ User must change password at next logon

☒ User cannot change password

☐ Password never expires

☐ Account is disabled

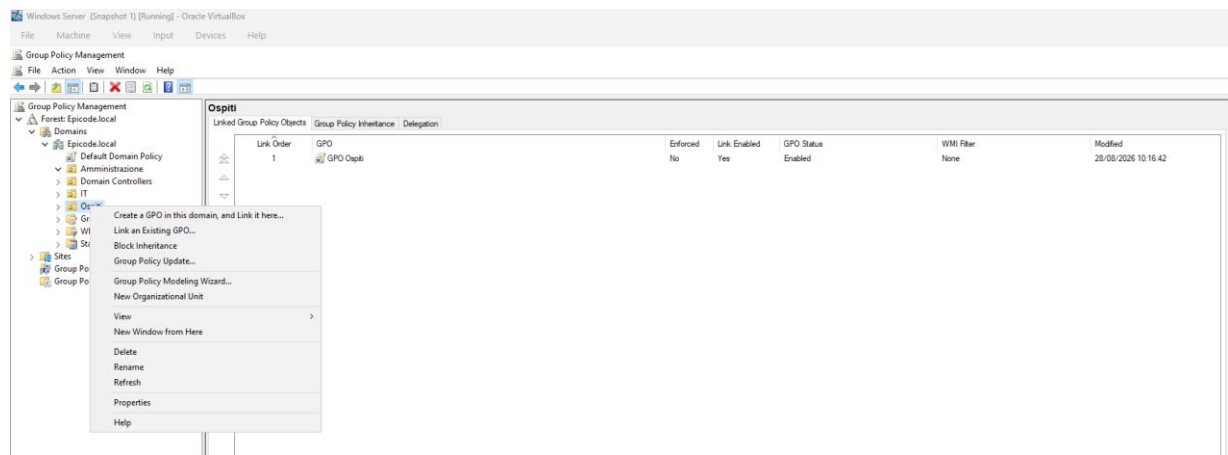
< Back Next > Cancel

2 - Sopra: Creazione di un utente nell'OU Ospiti con l'opzione User cannot change password abilitata.

All'interno del reparto IT è stata inoltre introdotta una differenza di ruolo: Marco Antonio rimane un tecnico IT standard, mentre Teresa Grassi viene successivamente autorizzata come amministratrice di sistema del server per poter utilizzare anche gli strumenti amministrativi.

2. Configurazione della GPO per gli Ospiti

Gli Ospiti rappresentano utenti temporanei delle postazioni pubbliche. È stata quindi creata una GPO dedicata e collegata direttamente all'OU Ospiti.



3 - Sopra: GPO Ospiti collegata all'OU Ospiti tramite Group Policy Management.

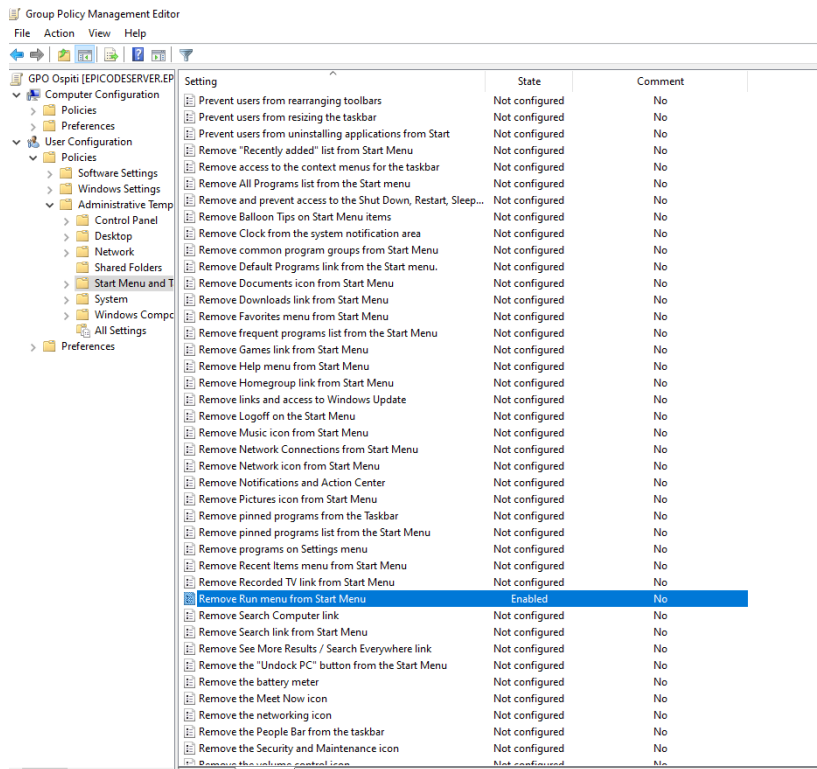
2.1 Restrizioni applicate agli Ospiti

La GPO è stata configurata per limitare le funzionalità di sistema non necessarie su una postazione pubblica: accesso al Pannello di controllo e alle Impostazioni, Prompt dei comandi, PowerShell e funzione Esegui. Le schermate della GPO documentano le policy configurate; la rimozione di Esegui è impostata tramite Remove Run menu from Start Menu. In questo modo l'utente può utilizzare la postazione senza disporre dei principali strumenti normalmente impiegati per modificare o amministrare la configurazione del sistema.

Group Policy Management Editor

File Action View Help			
GPO Ospiti [EPICODESERVER.EP]			
	Setting	State	Comment
Computer Configuration	Ctrl+Alt+Del Options		
Policies	Display		
Preferences	Driver Installation		
User Configuration	Folder Redirection		
Policies	Group Policy		
Software Settings	Internet Communication Management		
Windows Settings	Locale Services		
Administrative Temp	Logon		
Control Panel	Mitigation Options		
Desktop	Power Management		
Network	Removable Storage Access		
Shared Folders	Scripts		
Start Menu and T	User Profiles		
System	Download missing COM components	Not configured	No
Windows Comp	Century interpretation for Year 2000	Not configured	No
All Settings	Restrict these programs from being launched from Help	Not configured	No
Preferences	Do not display the Getting Started welcome screen at logon	Not configured	No
	Custom User Interface	Not configured	No
	Prevent access to the command prompt	Enabled	No
	Prevent access to registry editing tools	Enabled	No
	Don't run specified Windows applications	Not configured	No
	Run only specified Windows applications	Enabled	No
	Windows Automatic Updates	Not configured	No

4 - Sopra: Policy della GPO Ospiti nella sezione System: Prevent access to the command prompt e Prevent access to registry editing tools sono impostate su Enabled. Nello screenshot è inoltre visibile Run only specified Windows applications, attivata nel tentativo iniziale di whitelist e successivamente rimossa come descritto nella sezione 6.2.

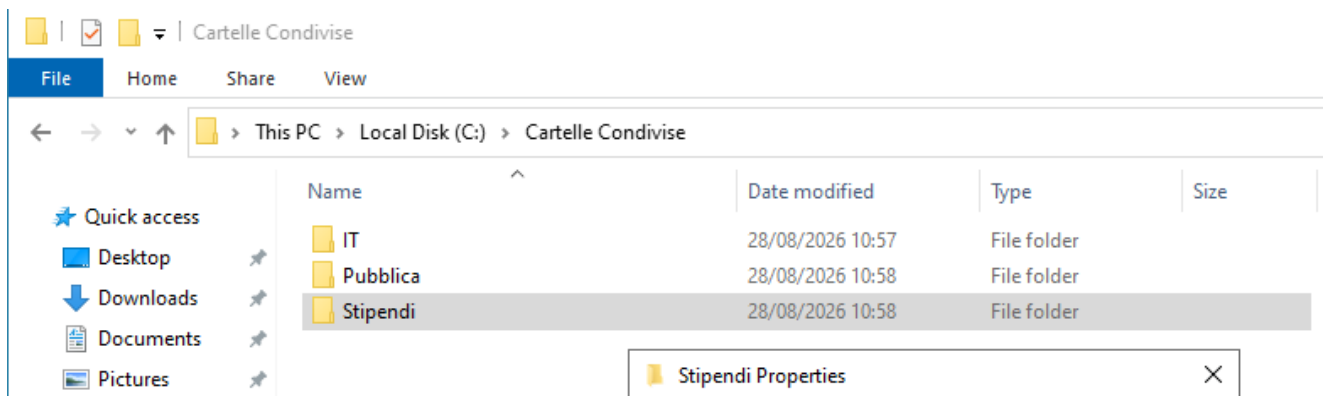


5 - Sopra: Policy Remove Run menu from Start Menu impostata su Enabled nella GPO Ospiti.

Gli Ospiti non ricevono autorizzazioni sulle cartelle condivise riservate ad Amministrazione, IT e Laboratori.

3. Creazione delle cartelle condivise

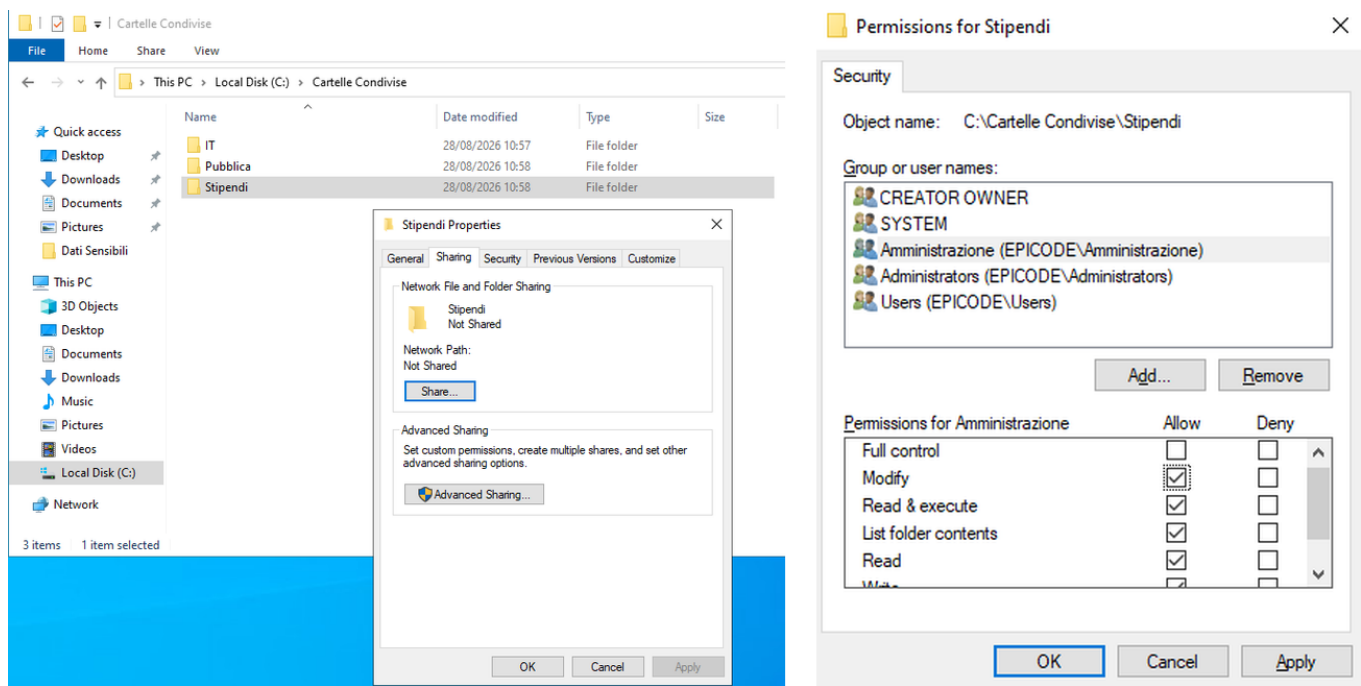
Sul server è stata creata la directory C:\Cartelle Condivise, contenente tre aree principali: IT, Pubblica e Stipendi. Per ogni cartella sono stati definiti sia i permessi di condivisione sia i permessi NTFS, in modo da separare l'accesso di rete dai diritti effettivi sul file system.



6 - Sopra: Directory C:\Cartelle Condivise con le tre cartelle IT, Pubblica e Stipendi create per i diversi reparti.

3.1 Cartella Stipendi - Amministrazione

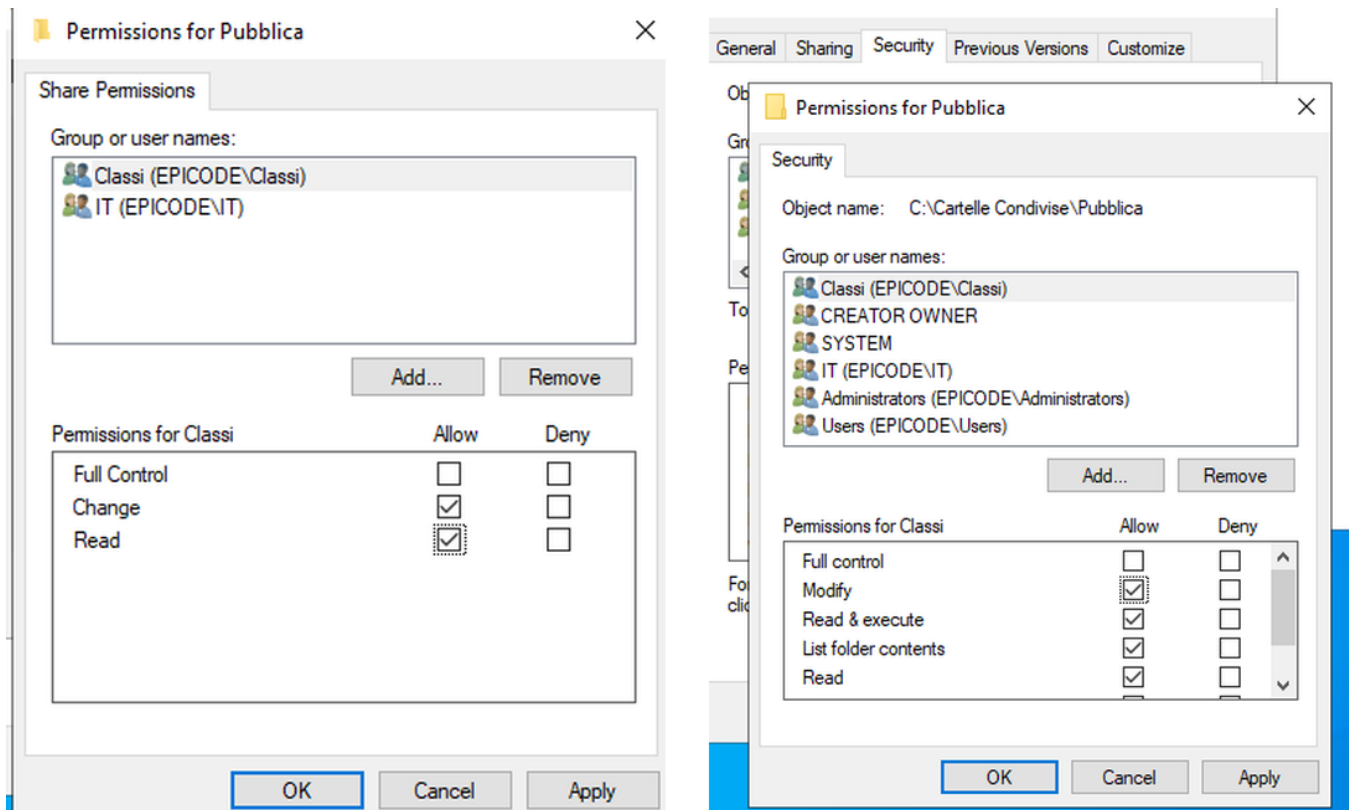
La cartella Stipendi è destinata ai dati amministrativi riservati. Il gruppo Amministrazione deve poter creare, modificare ed eliminare documenti, ma non amministrare le ACL: per questo sono stati scelti Change/Read nella condivisione e Modify nei permessi NTFS. Il reparto IT non viene autorizzato su questa cartella, mantenendo separato l'accesso tecnico dai dati sensibili.



7 - Sopra: Sinistra: permessi di condivisione della cartella Stipendi per Amministrazione. Destra: scheda Security con Modify assegnato al gruppo Amministrazione.

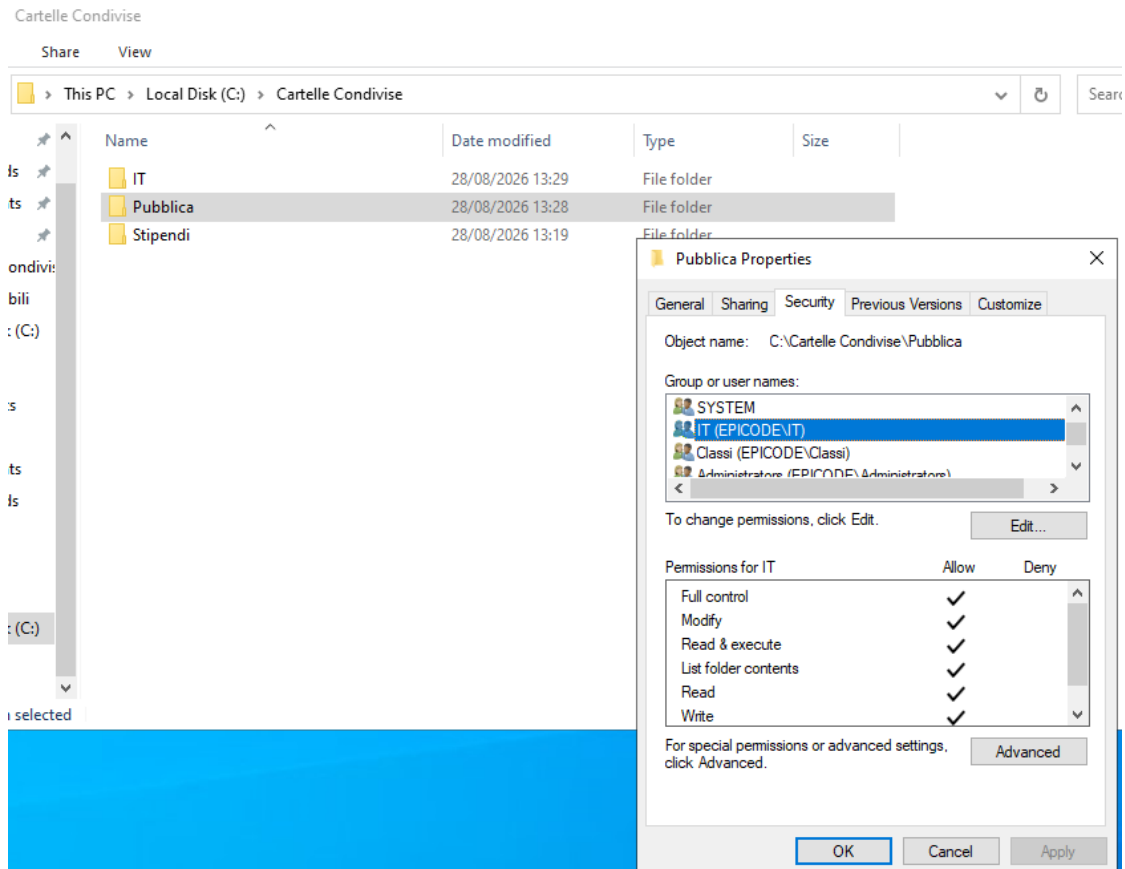
3.2 Cartella Pubblica - Laboratori e IT

La cartella Pubblica è destinata alle attività dei Laboratori. Al gruppo Laboratori sono stati assegnati Change e Read nella condivisione e Modify nei permessi NTFS, così da consentire la creazione e la modifica del materiale condiviso.



8 - Sopra: Sinistra: permessi Sharing della cartella Pubblica per Laboratori. Destra: scheda Security con Modify assegnato al gruppo Laboratori.

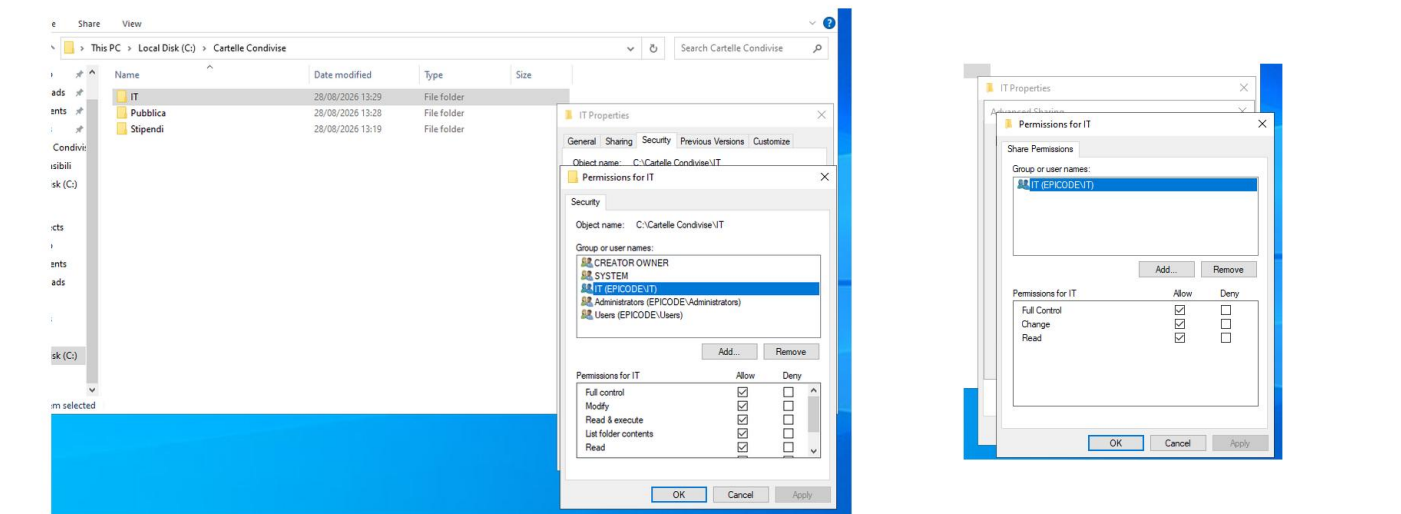
Il reparto IT deve poter amministrare la risorsa Pubblica per attività di gestione e manutenzione. Al gruppo EPICODE\IT è stato quindi assegnato Full Control nei permessi NTFS, oltre al Full Control nella condivisione.



9 - Sopra: Scheda Security della cartella Pubblica con il gruppo EPICODE\IT selezionato e Full Control assegnato.

3.3 Cartella IT

La cartella IT è riservata al reparto tecnico. Al gruppo EPICODE\IT è stato assegnato Full Control sia nella condivisione sia nei permessi NTFS, così da consentire la completa gestione della propria area di lavoro, inclusa la modifica delle autorizzazioni.



10 - Sopra: Sinistra: permessi NTFS della cartella IT con Full Control per EPICODE\IT. Destra: permessi di condivisione con Full Control, Change e Read.

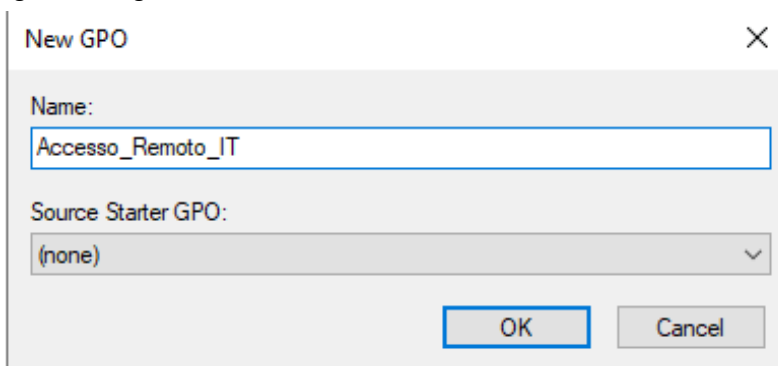
3.4 Riepilogo dei permessi sulle cartelle

Cartella	Gruppo	Sharing	NTFS
Stipendi	Amministrazione	Change / Read	Modify
IT	IT	Full Control	Full Control
Pubblica	IT	Full Control	Full Control
Pubblica	Laboratori	Change / Read	Modify

La separazione tra Stipendi e le aree amministrate da IT permette di mantenere la riservatezza dei dati sensibili pur consentendo al reparto tecnico di gestire le risorse operative e condivise.

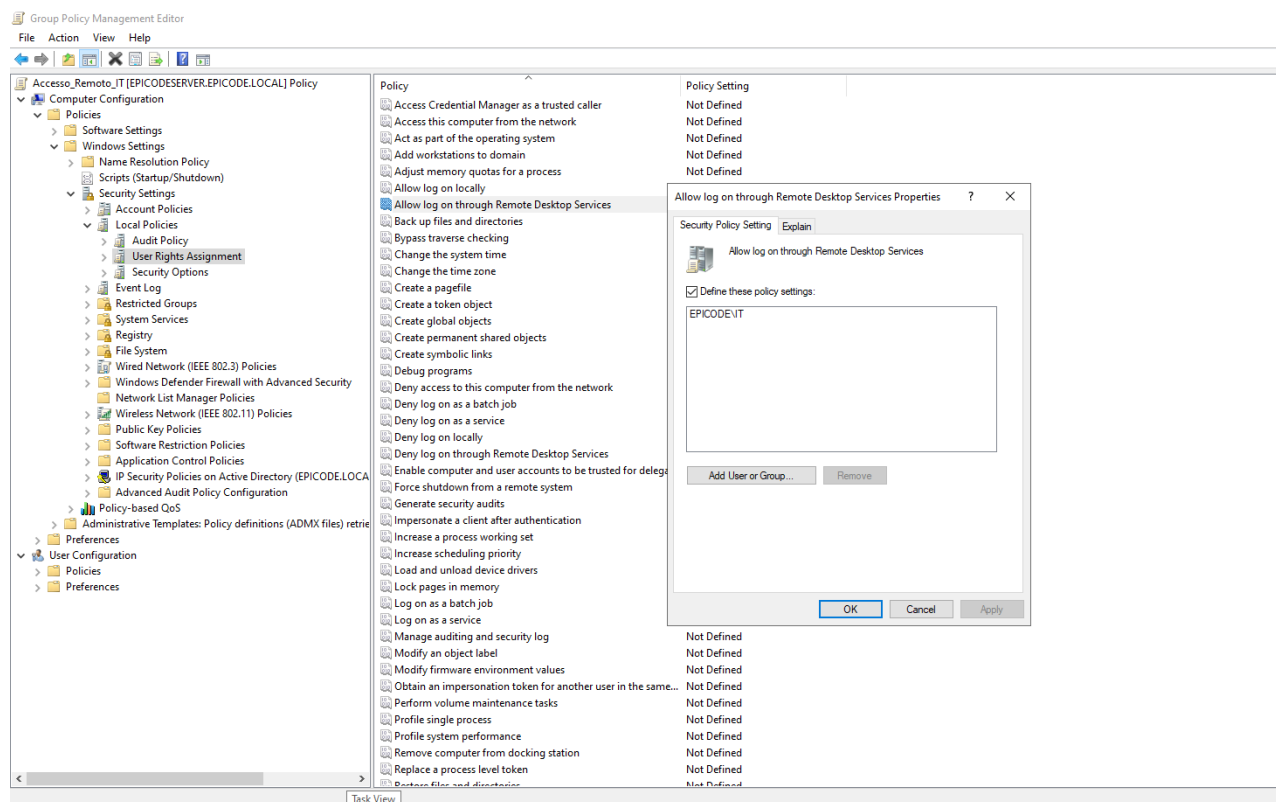
4. Accesso remoto al server per il gruppo IT

Per consentire al reparto IT di collegarsi al server è stata predisposta una GPO dedicata, denominata Accesso_Remoto_IT, nell'area Computer Configuration > Policies > Windows Settings > Security Settings > Local Policies > User Rights Assignment.



11 - Sopra: Creazione della GPO Accesso_Remoto_IT.

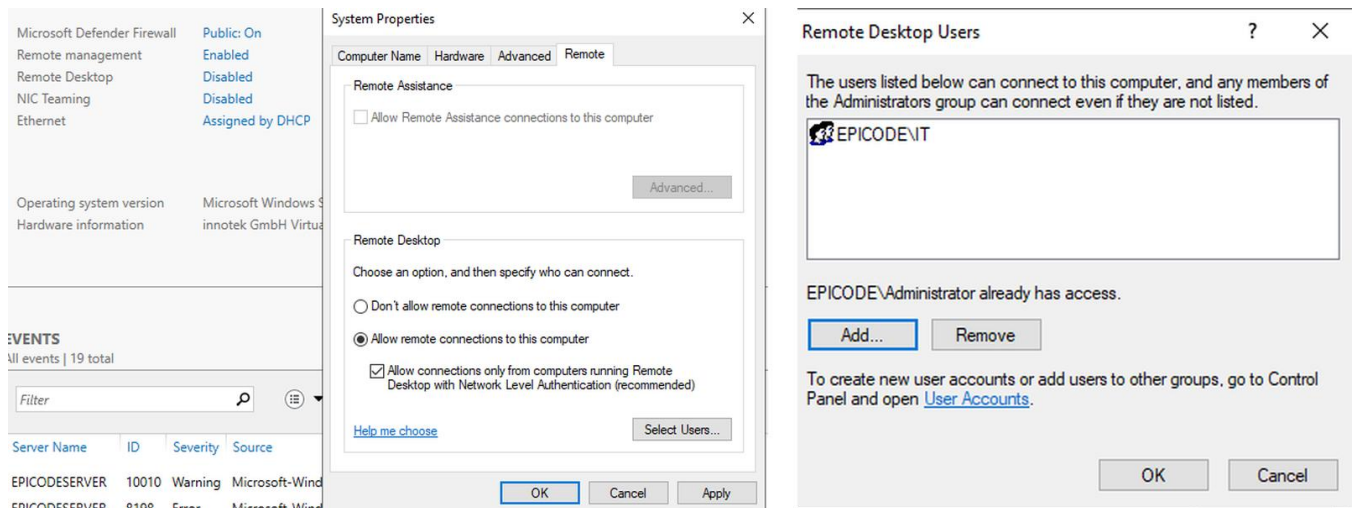
All'interno della policy è stato configurato il diritto Allow log on through Remote Desktop Services per il gruppo di dominio EPICODE\IT. Il diritto è quindi assegnato a entrambi gli utenti del reparto IT tramite l'appartenenza al gruppo.



12 - Sopra: Configurazione del diritto di accesso tramite Remote Desktop Services per il gruppo EPICODE\IT.

4.1 Abilitazione di Remote Desktop

Remote Desktop è stato abilitato nelle proprietà del server mantenendo attiva la Network Level Authentication. Il gruppo EPICODE\IT è stato poi aggiunto tra gli utenti autorizzati alla connessione.

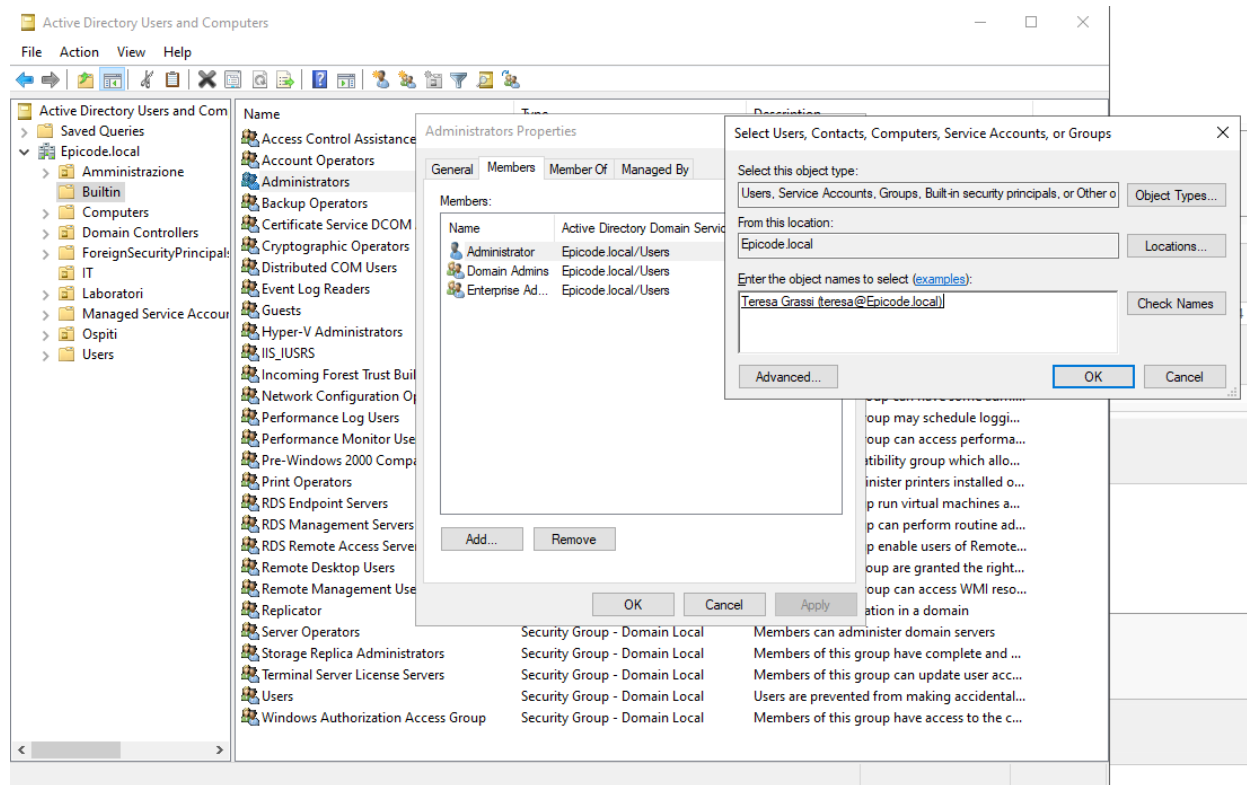


13 - Sopra: Sinistra: abilitazione delle connessioni Remote Desktop con Network Level Authentication. Destra: gruppo EPICODE\IT tra gli utenti autorizzati.

4.2 Privilegi amministrativi di Teresa Grassi

L'accesso RDP consente di aprire una sessione sul server, ma non attribuisce automaticamente privilegi amministrativi. Per distinguere i ruoli all'interno di IT, Teresa Grassi è stata aggiunta tramite Active Directory Users and Computers al gruppo integrato Administrators del dominio, mentre Marco Antonio è rimasto un tecnico IT standard. Teresa può quindi utilizzare Server Manager e gli altri strumenti che richiedono elevazione; Marco conserva i privilegi operativi assegnati al gruppo IT senza diventare amministratore del server.

La scelta simula una struttura in cui solo alcuni tecnici IT svolgono il ruolo di amministratore di sistema, applicando una separazione dei privilegi anche all'interno dello stesso reparto.



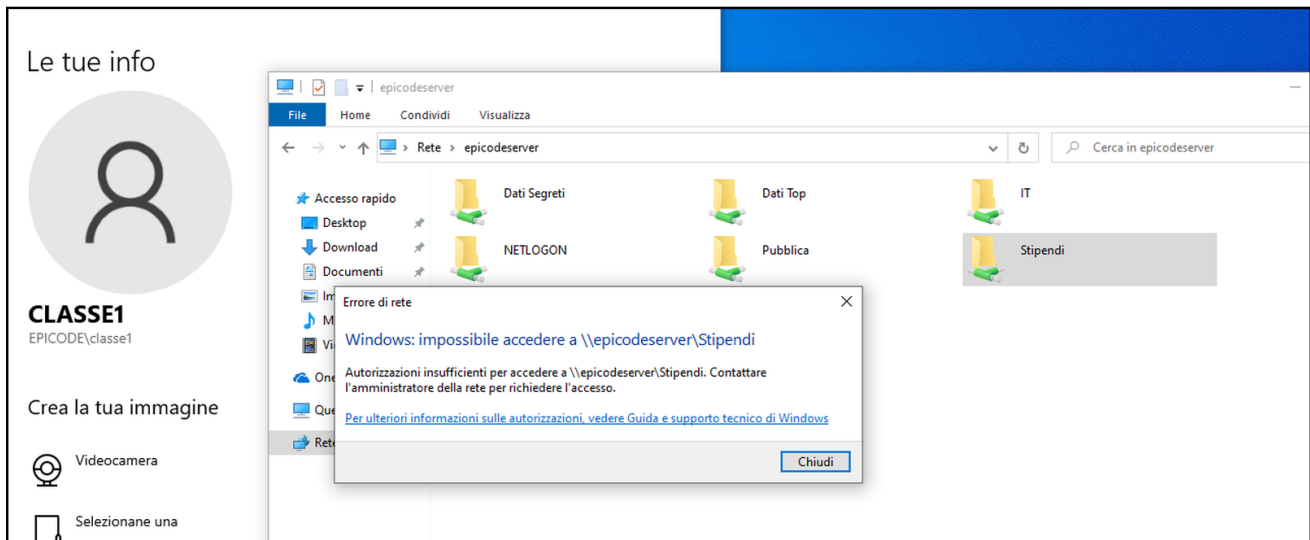
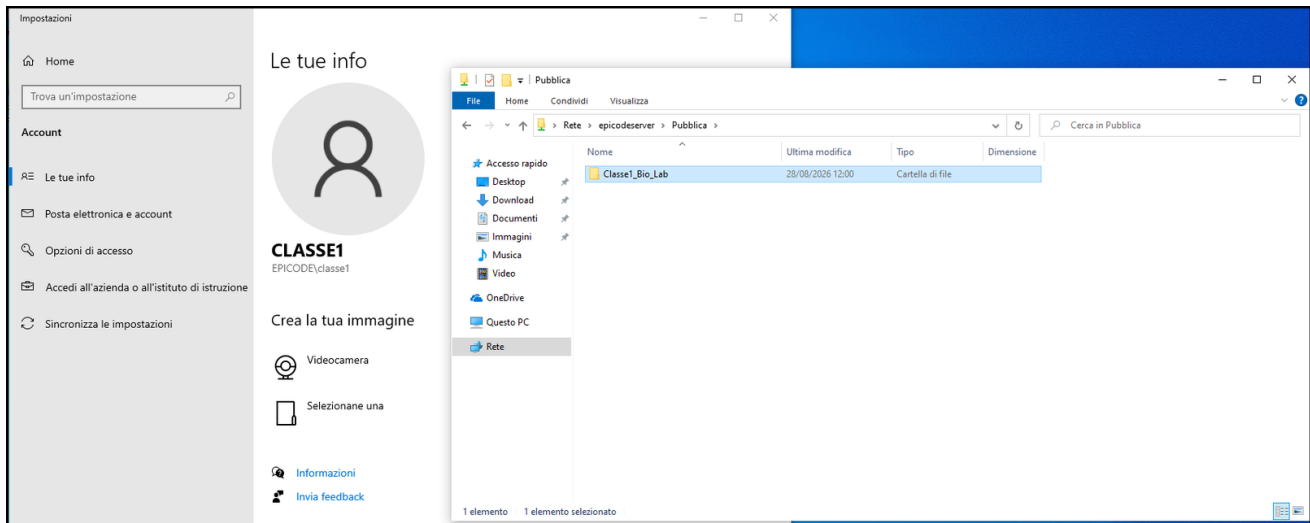
14 - Sopra: Teresa Grassi viene aggiunta al gruppo integrato Administrators, ottenendo i privilegi amministrativi necessari per gestire il server e utilizzare Server Manager.

5. Verifica sul client Windows 10

Per verificare l'effettiva applicazione dei permessi è stato utilizzato un client Windows 10 collegato al dominio EPICODE.LOCAL. È stato effettuato l'accesso con un utente rappresentativo per ciascun gruppo: Chiara Rossi per Amministrazione, Teresa Grassi per IT, classe1 per Laboratori e ospite1 per Ospiti. I test hanno verificato sia gli accessi consentiti sia quelli negati.

5.1 Verifica del gruppo Laboratori

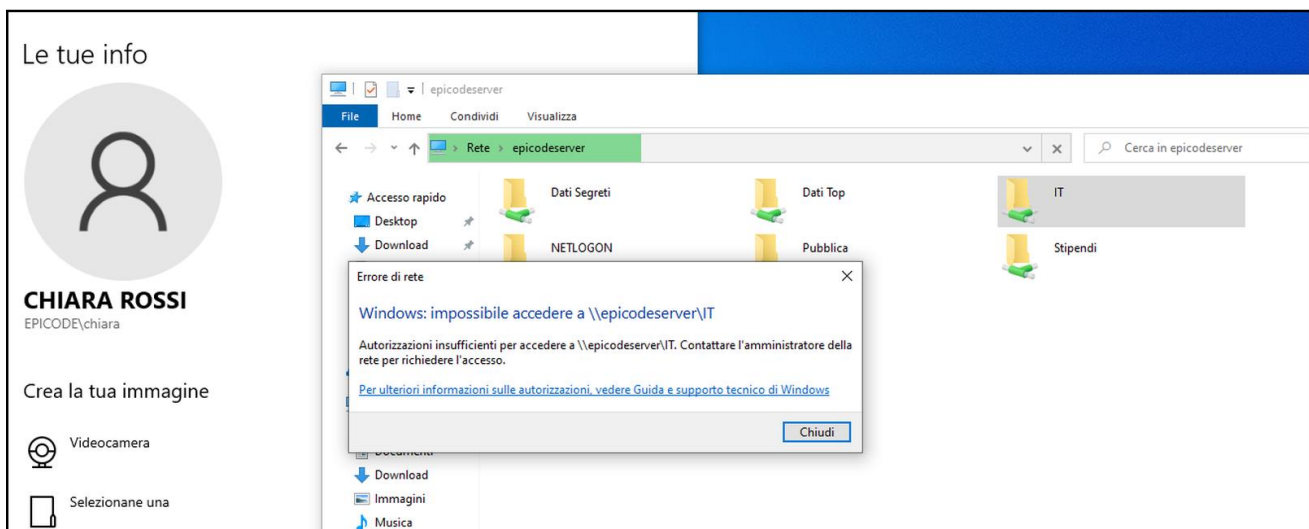
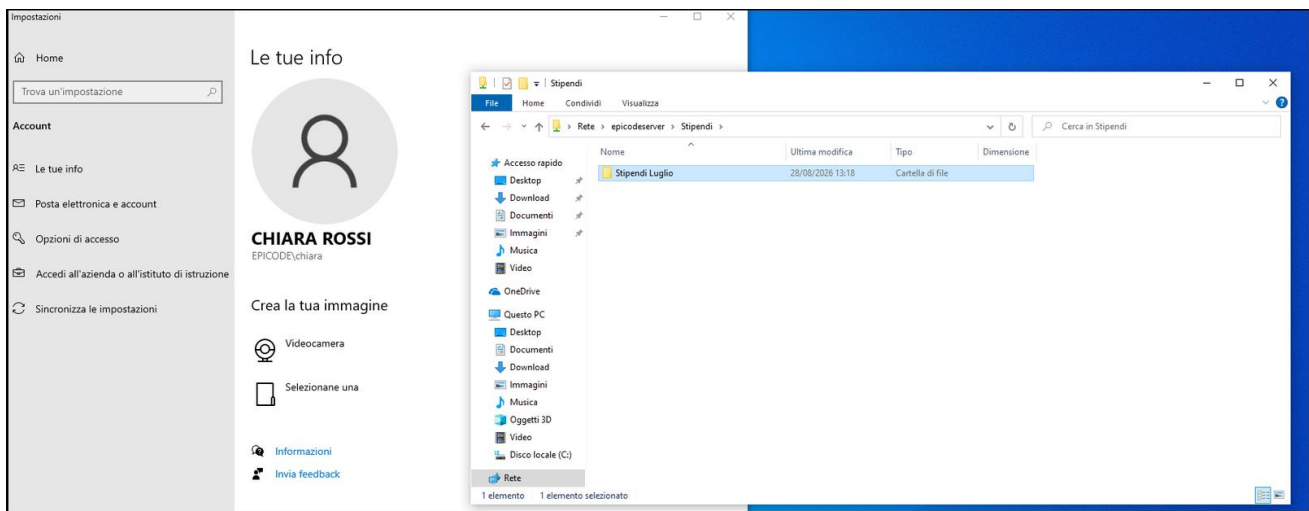
Con l'account EPICODE\classe1 è stato possibile accedere alla condivisione Pubblica e utilizzare il contenuto presente. Il tentativo di aprire la cartella Stipendi ha invece restituito un errore di autorizzazioni insufficienti. Il risultato conferma che gli utenti dei Laboratori possono lavorare sulla risorsa Pubblica ma non accedere ai dati amministrativi riservati.



15 - Sopra: In alto: accesso alla cartella Pubblica con l'utente classe1. In basso: accesso negato alla cartella Stipendi.

5.2 Verifica del gruppo Amministrazione

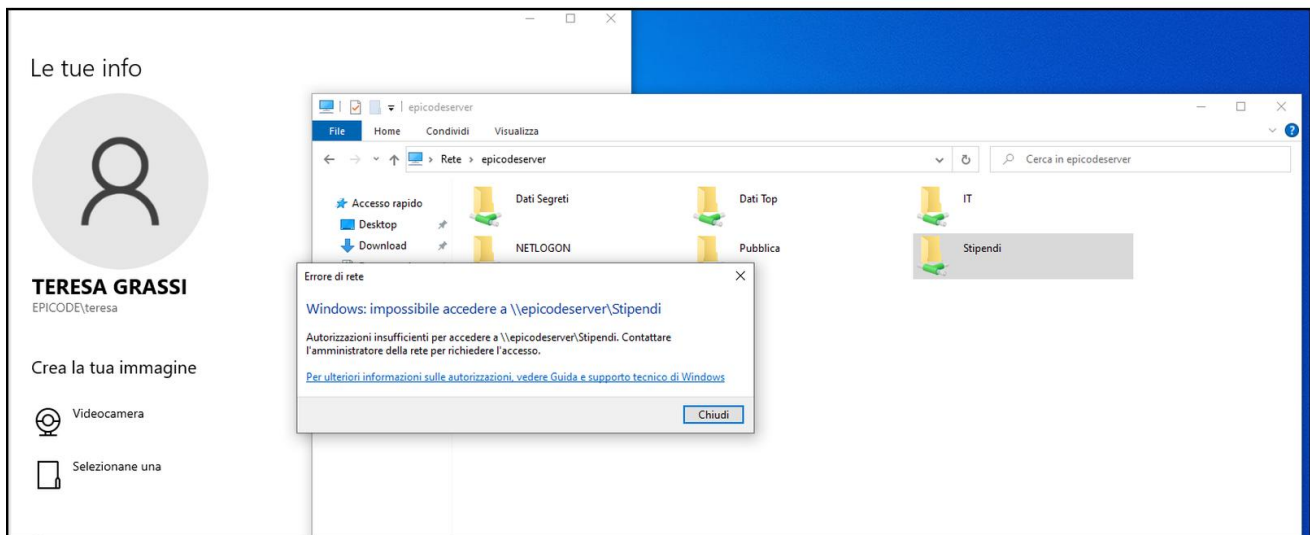
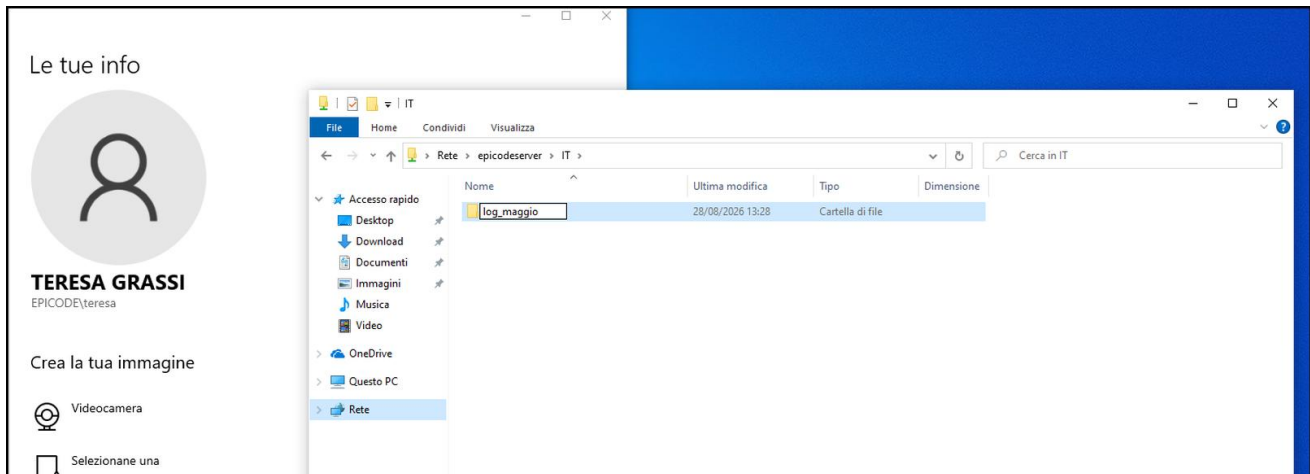
Il test con Chiara Rossi ha confermato l'accesso alla cartella Stipendi con possibilità di creare e modificare il contenuto. Nello screenshot è visibile la creazione della cartella Stipendi Luglio. Il tentativo di accedere alla cartella IT è stato invece negato; è stato verificato anche il mancato accesso alla cartella Pubblica. In questo modo l'account amministrativo può lavorare esclusivamente sulle risorse per cui è stato autorizzato.



16 - Sopra: In alto: Chiara Rossi accede alla cartella Stipendi e ne modifica il contenuto. In basso: accesso negato alla cartella IT.

5.3 Verifica del gruppo IT

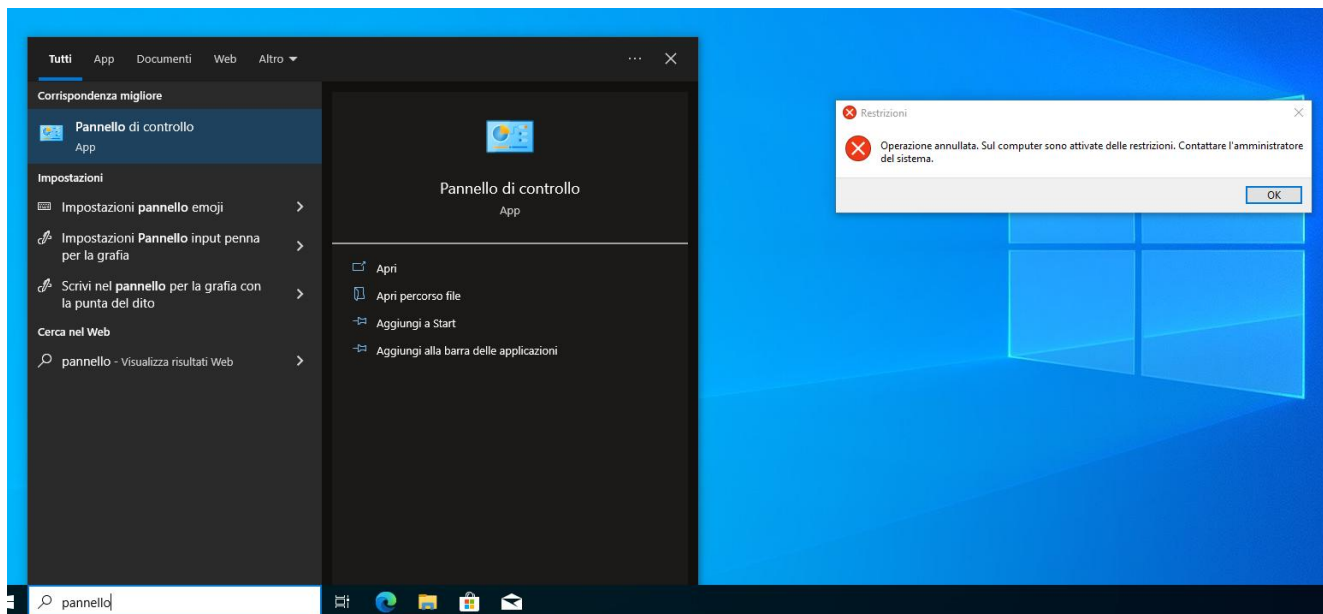
Con l'account Teresa Grassi è stato verificato l'accesso alla cartella IT con possibilità di creare e modificare elementi. È stato inoltre verificato con esito positivo l'accesso alla cartella Pubblica, mentre il tentativo di aprire Stipendi è stato bloccato. Il risultato conferma che i privilegi tecnici non concedono automaticamente accesso ai dati riservati dell'Amministrazione.



17 - Sopra: In alto: Teresa Grassi accede alla cartella IT e crea la cartella log_maggio. In basso: accesso negato alla cartella Stipendi.

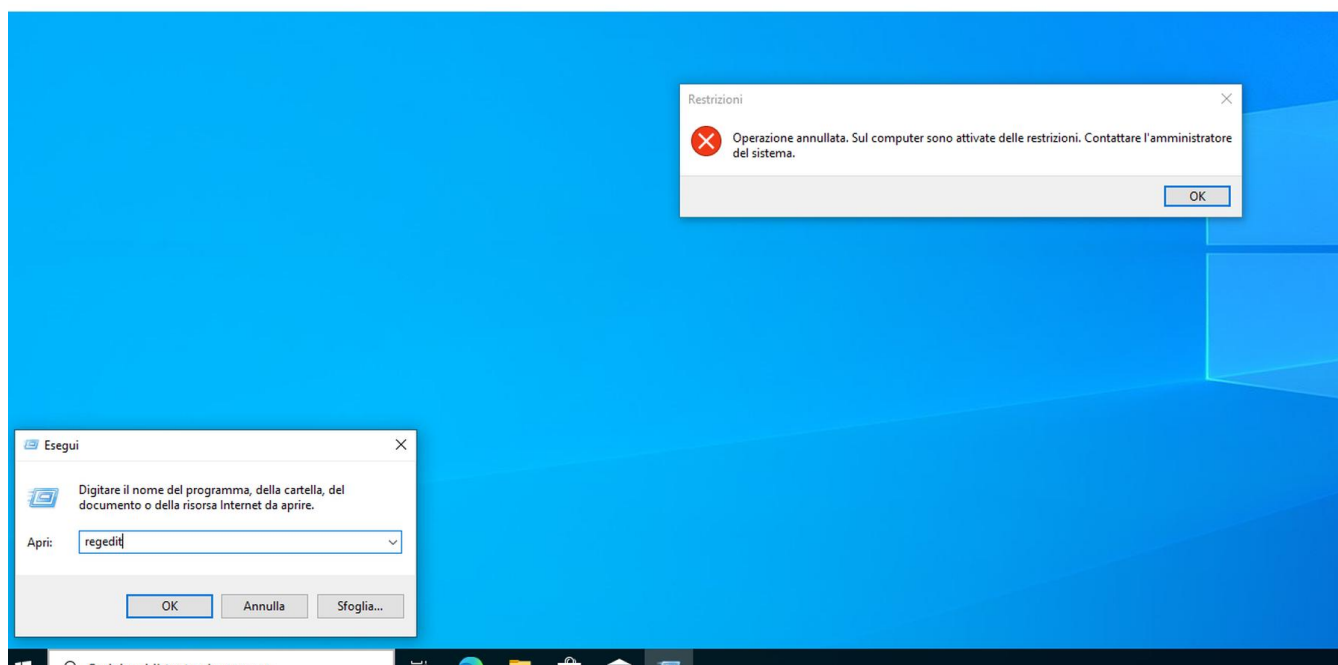
5.4 Verifica delle restrizioni per gli Ospiti

La GPO Ospiti è stata verificata utilizzando l'account ospite1. Il tentativo di aprire il Pannello di controllo ha prodotto il messaggio di restrizione previsto. Sono stati inoltre verificati il blocco di PowerShell e del Prompt dei comandi e la policy Remove Run menu from Start Menu, configurata per rimuovere il comando Esegui dall'interfaccia dell'utente. Nel test è stato inoltre tentato l'avvio di Registry Editor tramite Esegui: Windows ha annullato l'operazione a causa delle restrizioni applicate. Il risultato conferma che l'utente Ospite dispone di un ambiente più limitato rispetto agli altri gruppi.



18 - Sopra: Tentativo di apertura del Pannello di controllo con ospite1: Windows segnala che sul computer sono attive restrizioni.

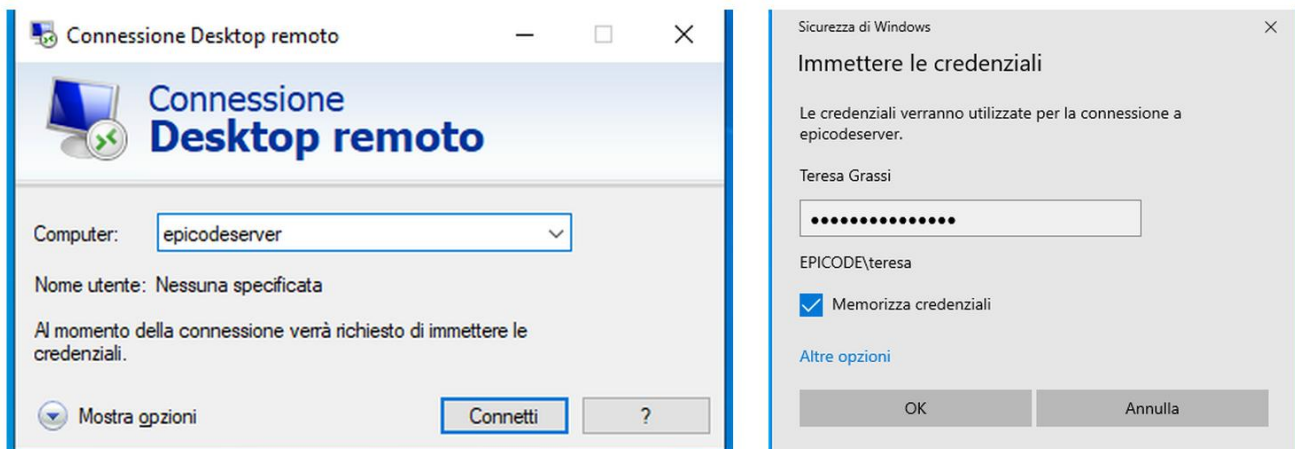
Remove Network Connections from Start Menu	Not configured	No
Remove Network icon from Start Menu	Not configured	No
Remove Notifications and Action Center	Not configured	No
Remove Pictures icon from Start Menu	Not configured	No
Remove pinned programs from the Taskbar	Not configured	No
Remove pinned programs list from the Start Menu	Not configured	No
Remove programs on Settings menu	Not configured	No
Remove Recent Items menu from Start Menu	Not configured	No
Remove Recorded TV link from Start Menu	Not configured	No
Remove Run menu from Start Menu	Enabled	No
Remove Search Computer link	Not configured	No
Remove Search link from Start Menu	Not configured	No
Remove See More Results / Search Everywhere link	Not configured	No
Remove the "Undock PC" button from the Start Menu	Not configured	No
Remove the bottom watermark	Not configured	No



19 - Sopra: In alto: policy Remove Run menu from Start Menu impostata su Enabled nella GPO Ospiti. In basso: test con ospite1; il tentativo di avviare Registry Editor tramite Esegui viene annullato dalle restrizioni di sistema.

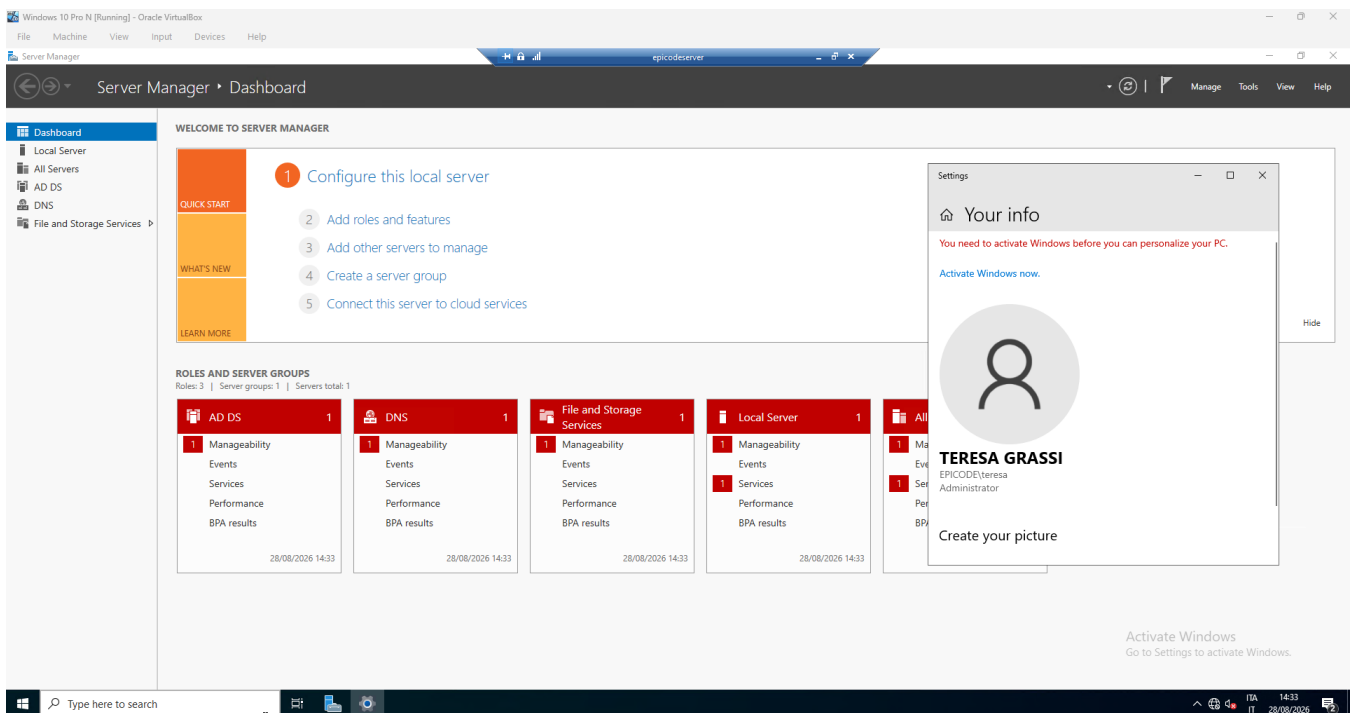
5.5 Verifica dell'accesso Remote Desktop

Il test RDP è stato eseguito dal client Windows 10 verso epicodeserver. È stata avviata Connessione Desktop remoto, specificato il server e inserite le credenziali di EPICODE\teresa. La connessione è stata accettata, confermando l'efficacia dell'autorizzazione assegnata al gruppo IT.



20 - Sopra: Sinistra: connessione RDP verso epicodeserver. Destra: autenticazione con l'account EPICODE\teresa.

Una volta stabilita la sessione, Teresa ha effettuato l'accesso al desktop del server. Dopo l'assegnazione dei privilegi amministrativi, è stato possibile aprire Server Manager utilizzando il suo stesso account.



21 - Sopra: Server Manager aperto nella sessione Remote Desktop di Teresa Grassi; nella finestra delle informazioni account l'utente EPICODE\teresa risulta Administrator.

5.6 Esito complessivo dei test

Utente / gruppo	Verifica eseguita	Esito
classe1 / Laboratori	Pubblica consentita; Stipendi negata	Corretto
Chiara Rossi / Amministrazione	Stipendi consentita; IT e Pubblica negata	Corretto
Teresa Grassi / IT	IT e Pubblica consentite; Stipendi negata	Corretto
ospite1 / Ospiti	Pannello di controllo, CMD, PowerShell e strumenti di sistema limitati	Corretto
Teresa Grassi / RDP	Accesso a epicodeserver e apertura Server Manager	Corretto

6. Problemi riscontrati e soluzioni

Durante la configurazione e la fase di verifica sono emersi due problemi principali. Entrambi hanno richiesto di rivedere l'impostazione iniziale e hanno permesso di distinguere meglio tra il semplice accesso a una risorsa e i privilegi effettivamente necessari per utilizzarla.

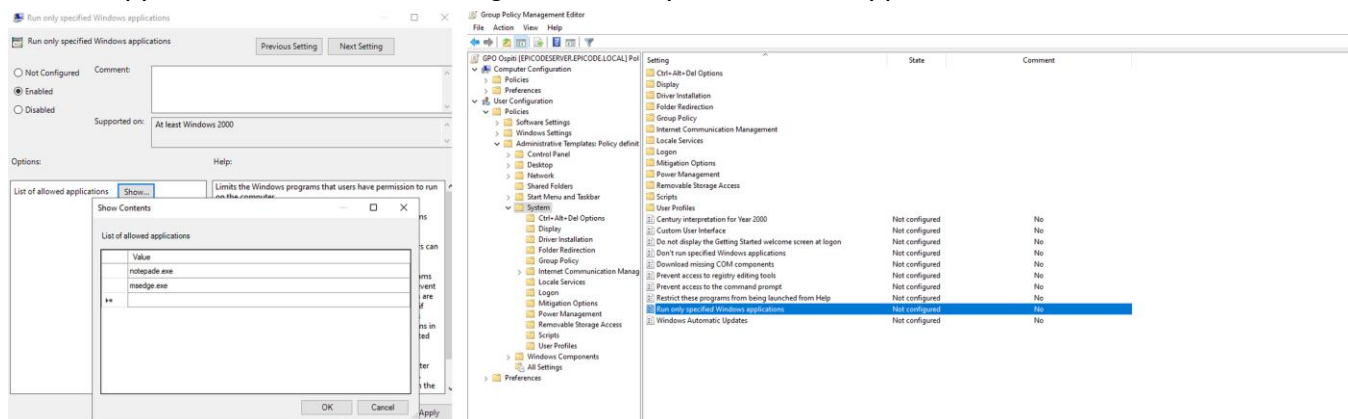
6.1 Accesso Remote Desktop e privilegi amministrativi

Nel primo test Teresa Grassi riusciva a collegarsi correttamente al server tramite Remote Desktop, perché il gruppo EPICODEIT era stato autorizzato al logon RDP. Una volta aperta la sessione remota, però, il tentativo di avviare Server Manager richiedeva credenziali amministrative; utilizzando quelle di Teresa veniva restituito l'errore "Logon failure: the user has not been granted the requested logon type at this computer". Il problema ha mostrato che il diritto di accedere al server tramite RDP e il diritto di amministrarlo sono due autorizzazioni distinte.

Per risolvere il problema, Teresa Grassi è stata aggiunta al gruppo integrato Administrators tramite Active Directory Users and Computers. Dopo un nuovo accesso, Teresa ha potuto aprire Server Manager anche durante la sessione RDP. Marco Antonio è invece rimasto un tecnico IT standard: entrambi gli utenti del gruppo IT possono collegarsi in Desktop remoto, ma solo Teresa dispone dei privilegi amministrativi. La soluzione mantiene quindi separato l'accesso remoto dall'elevazione dei privilegi e applica il principio del minimo privilegio anche all'interno del reparto IT.

6.2 Limitazione delle applicazioni per gli Ospiti

L'idea iniziale per gli utenti Ospiti era realizzare una postazione simile a un terminale pubblico di biblioteca, consentendo solamente Microsoft Edge e Blocco note. È stata quindi provata la policy Run only specified Windows applications, inserendo msedge.exe e notepad.exe tra le applicazioni consentite.



22 - Sopra: Sinistra: tentativo iniziale di limitare gli Ospiti a notepad.exe e msedge.exe tramite Run only specified Windows applications. Destra: la policy è stata successivamente riportata a Not configured.

Durante i test è stato però possibile continuare a utilizzare componenti come Esplora file e Microsoft Store e creare o modificare file locali. La policy Run only specified Windows applications non ha quindi prodotto, da sola, una whitelist completa dell'ambiente Windows: alcune componenti della shell e applicazioni avviate

attraverso meccanismi diversi continuavano a essere disponibili. Per questo l'idea iniziale di una postazione limitata esclusivamente a Edge e Blocco note non è stata mantenuta.

La soluzione adottata è stata quindi quella di rimuovere la whitelist e mantenere restrizioni più semplici e verificabili: blocco del Pannello di controllo e delle Impostazioni, del Prompt dei comandi e di PowerShell, rimozione del comando Esegui dal menu Start e limitazione degli strumenti di sistema non consentiti. Gli screenshot della GPO e i test con ospite1 mostrano che queste restrizioni vengono applicate correttamente. Per ottenere una vera postazione kiosk limitata a poche applicazioni sarebbe stato necessario utilizzare un meccanismo di controllo più specifico, non implementato in questo laboratorio.

7. Conclusioni

I test dal client Windows 10 hanno confermato il corretto funzionamento dei permessi sulle cartelle condivise, delle restrizioni applicate agli Ospiti e dell'accesso Remote Desktop. Ogni utente riesce ad accedere solamente alle risorse previste dal proprio ruolo: Amministrazione lavora su Stipendi, IT gestisce le aree tecniche e Pubblica, i Laboratori utilizzano Pubblica e gli Ospiti ricevono limitazioni sulle principali funzionalità di amministrazione del sistema. La fase di troubleshooting ha inoltre permesso di correggere sia i privilegi necessari per Server Manager sia l'impostazione iniziale delle restrizioni applicative agli Ospiti.

All'interno del reparto IT è stata inoltre differenziata la responsabilità degli utenti: Marco Antonio mantiene il ruolo di tecnico standard, mentre Teresa Grassi dispone dei privilegi di amministratrice di sistema e può utilizzare Server Manager anche durante una sessione RDP. La configurazione dimostra quindi sia la gestione dei permessi basata sui gruppi sia l'assegnazione mirata di privilegi aggiuntivi a un singolo utente quando il ruolo operativo lo richiede.

Nel complesso, la configurazione applica il principio del minimo privilegio: i dati sensibili di Stipendi restano separati dall'amministrazione tecnica, gli utenti dei Laboratori accedono solamente alle risorse condivise necessarie e gli Ospiti dispongono di un ambiente fortemente limitato. Lo stesso principio è applicato anche al reparto IT: Marco Antonio e Teresa Grassi hanno entrambi accesso al server tramite Desktop Remoto in quanto membri del gruppo IT, ma i privilegi amministrativi sono stati assegnati esclusivamente a Teresa Grassi e non all'intero gruppo.